MODULE 09 · DOMAIN 1 - PLAN AND MANAGE AN AZURE AI SOLUTION

Guardrails and content safety

Controls, intervention points, severity thresholds, Prompt Shields, spotlighting, protected material and blocklists.

DOMAIN 1 - Plan and manage WEIGHT 25-30% MODULE 09 of 39

admin@sthithapragna.com

A control answers three questions: **what risk**, **where** to look for it, and **what to do** when it's found.

The four intervention points

INTERVENTION POINT	WHAT IS SCANNED	APPLIES TO
User input	The prompt sent to the model or agent	Models and agents
Tool call (preview)	What the agent is about to send to a tool	Agents only
Tool response (preview)	What a tool sends back to the agent	Agents only
Output	The final answer returned to the user	Models and agents

ON THE EXAM

Tool call and tool response scanning need moderation support from the tool itself, such as AI Search, OpenAPI or Bing grounding.

The risks a control can detect

RISK	WHAT IT CATCHES
Hate, sexual, violence, self-harm	Harmful content, scored by severity
User prompt attacks	Jailbreak attempts typed by the user
Indirect attacks	Instructions hidden in documents, emails or tool results
Protected material: text and code	Known copyrighted text, or code from public repositories
PII (preview)	Personal information in model output
Groundedness (preview)	Responses not supported by the provided sources

WATCH FOR THIS

Groundedness and spotlighting controls apply to models only. Added to an agent's guardrail, they have no effect.

Annotate, or annotate and block?

ANNOTATE

Flag and let it through

- Detection results returned with the response
- Nothing is stopped
- Useful for measuring before enforcing
- Models only, not agents

ANNOTATE AND BLOCK

Flag and stop

- The request or response is halted
- Detection details still returned
- The standard action in production
- The only action available for agents

ON THE EXAM

Turning a harm filter off, or setting it to annotate only, requires Microsoft's approval for modified guardrails.

The threshold is the lowest severity that gets blocked

THRESHOLD	BLOCKS	ALLOWS
Low	Low, medium and high	Safe only. The strictest setting
Medium (default)	Medium and high	Safe and low
High	High only	Safe, low and medium. The most permissive

ON THE EXAM

Content rated 'safe' is never filtered. The default for all four harm categories, on input and output, is Medium.

'Set it to High' means **block less**, not block more. Even one of Microsoft's own pages labels these the wrong way round.

Two kinds of prompt injection

USER PROMPT ATTACKS

The attacker is the user

- Jailbreak attempts typed directly
- Role-play tricks, fake system rules, encoding
- Scanned at user input

INDIRECT ATTACKS

The attack hides in content

- Instructions inside documents, emails, web pages
- The user may be innocent
- Scanned in documents or tool responses
- Documents must be marked as documents

THE SIGNAL

If the harmful instruction came from something the agent read, not something the user typed, it's an indirect attack.

Spotlighting

- Strengthens defence against **indirect attacks** in third-party documents.
- Transforms document content with **base-64 encoding**, so the model treats it as less trusted.
- **Off by default.** No direct charge, but it **adds tokens**, which raises cost.
- Large documents can **exceed input size limits** once encoded.
- Applies to models only, not agents.

> ON THE EXAM
>
> Use spotlighting for apps that process uploaded files or web content, where indirect attacks are most likely.

Blocklists

- Block **specific terms** the classifiers wouldn't treat as harmful: competitor names, project code names.
- Each item is an **exact match** or a **regular expression**.
- Microsoft also provides a prebuilt **profanity blocklist**, in English.
- Apply to input, output, or both, and combine several lists in one guardrail.
- New terms take **about five minutes** to take effect. Support is limited to Azure OpenAI models.

> THE TIEBREAKER
>
> Classifiers judge harm. Blocklists enforce your own vocabulary rules. They solve different problems.

How guardrails apply to agents

- An agent's guardrail **fully overrides** its model deployment's guardrail. Nothing is merged.
- With no guardrail assigned, an agent **inherits** its model deployment's guardrail.
- Models get **Microsoft.DefaultV2** unless you assign something else.
- An agent guardrail with no output control means **output is not scanned**.
- Protect tool calls and tool responses explicitly. They aren't scanned unless you add controls.

> THE SIGNAL
>
> 'Strict model guardrail, weak agent guardrail' means the agent runs with the weak one.

Requirement to control

REQUIREMENT	RISK, INTERVENTION POINT, ACTION
Stop users jailbreaking a chatbot	User prompt attacks, user input, block
Stop hidden instructions in emails an agent reads	Indirect attacks, tool response, block
Stop an agent sending harmful content to a tool	Harm category, tool call, block
Never mention competitor names	Custom blocklist, output
Avoid returning copyrighted lyrics or articles	Protected material for text, output

ON THE EXAM

If a scenario names where the harm enters or leaves, that is the intervention point. Match it exactly.

Azure AI Content Safety as a service

- Guardrails use Content Safety's classifiers. You can also **call Content Safety directly**.
- Analyse **text and images**, for example user uploads before they're stored.
- **Custom categories:** train detection of your own kinds of unwanted content from examples.
- Prompt Shields, groundedness detection and protected material, as standalone APIs.
- Use it where guardrails don't reach: other models, user content, non-Foundry apps.

> ON THE EXAM
>
> Guardrails protect model and agent traffic. Content Safety protects anything else you choose to send it.

A hospital's triage assistant helps nurses describe injuries. Many legitimate descriptions of wounds are being blocked by the violence category, which uses the default setting.

The clinical safety lead wants to keep blocking the most graphic violent content, but stop blocking ordinary medical descriptions.

What should the team change?

A Set the violence threshold to Low for both input and output.

B Set the violence threshold to High for input and output.

C Turn the violence category off for this deployment.

D Add common injury terms to a custom blocklist.

◆ PAUSE AND DECIDE

What should the team change?

A. Threshold Low.

Low blocks low, medium and high. That blocks even more medical content.

B. Threshold High.

Only high-severity content is blocked, so ordinary descriptions pass and graphic content stays blocked.

C. Turn violence off.

Removes all violence protection, contradicts the requirement, and needs Microsoft approval.

D. Blocklist injury terms.

A blocklist blocks terms. It would block these descriptions more, not less.

THE SIGNAL

'Block less' means moving the threshold up towards High. The label sounds strict; the behaviour is permissive.

> An agent reads customer emails through a tool and drafts replies. One email contained hidden text telling the agent to forward all invoices to an outside address.
>
> The agent attempted it. The customer who sent the email had typed nothing unusual in the chat.

Which control should the team add to the agent's guardrail?

A. User prompt attacks at the user input point, set to annotate and block.

B. A stricter Low threshold for hate and violence on the agent's output.

C. A sentence in the agent's instructions saying to ignore orders in emails.

D. Indirect attacks at the tool response point, set to annotate and block.

◆ PAUSE AND DECIDE

Which control should the team add to the agent's guardrail?

A. User prompt attacks at user input.
Scans what the user typed. The attack came from an email the tool returned.

B. Stricter harm thresholds on output.
Forwarding invoices isn't hateful or violent. Harm classifiers won't see it.

C. Tell the agent to ignore email orders.
Helps a little, but instructions are exactly what an injection overrides.

D. Indirect attacks at tool response.
Scans tool output for hidden instructions and stops the agent before it acts.

THE SIGNAL

The attack entered through a tool's response. That names both the risk and the intervention point.

A retailer's shopping assistant must never mention two named competitors, or an unreleased product code-named Project Falcon, in its answers.

Testing shows none of these terms is flagged by any harm category, because none of them is harmful content.

What should the team configure?

A. A custom blocklist containing the terms, applied to the output.

B. The Low threshold on all four harm categories, for input and output.

C. The protected material for text control, applied to the output.

D. The Prompt Shields user prompt attacks control, applied to input.

◆ PAUSE AND DECIDE

What should the team configure?

A Custom blocklist on output.

Blocks exactly these terms, as exact matches or patterns, wherever they appear in answers.

B Low thresholds everywhere.

Blocks more harmful content, but these terms aren't harmful, so they still pass.

C Protected material for text.

Detects known copyrighted text such as lyrics, not your own sensitive names.

D User prompt attacks on input.

Detects jailbreaks, and on input. The requirement is about what the assistant says.

THE SIGNAL

'Not harmful, but not allowed' is the definition of a blocklist term.

> A model deployment uses a strict custom guardrail that blocks violence on input and output. An agent built on that deployment has its own guardrail.
>
> The agent's guardrail contains only user input controls. Testers find the agent's answers can include violent content that is never blocked.

Why is violent output getting through?

A. Guardrail changes take up to a day to reach agents after assignment.

B. Agents run without guardrails when they call tools during a conversation.

C. The agent's guardrail replaces the model's and has no output controls.

D. The output intervention point is not available for agents, only models.

◆ PAUSE AND DECIDE

Why is violent output getting through?

A. Changes take a day.
No such delay explains a permanent gap. The configuration itself is the cause.

B. No guardrails during tool calls.
Guardrails still apply; tool points just need explicit controls.

C. Agent guardrail overrides, with no output control.
An agent's guardrail fully replaces its model's. Nothing scans output here.

D. Output not available for agents.
Output is available for agents. It just wasn't configured.

THE TIEBREAKER

Nothing is merged. An agent's own guardrail is the whole story, so check it has every intervention point you need.

Guardrails in five lines

- **Control = risk + intervention point + action.** A guardrail is a set of controls.
- **Threshold is the lowest severity blocked.** High blocks least; Low blocks most. Default Medium.
- **User typed it:** user prompt attack. **System read it:** indirect attack.
- **An agent's guardrail fully overrides its model's.** Tool points need explicit controls.
- **Blocklists** for 'not harmful but not allowed'. Content Safety where guardrails don't reach.

> ON THE EXAM
>
> Next, module 10: safety evaluations, red teaming, audit trails, provenance and governing agent behaviour.